

## Section 05

# Industrial Security (Bachelor)



## Section 05 – Threat Landscape

### Threat Landscape

*Lecture Notes*

Department of Computer Science

1 Threat Actors and Frameworks

2 Case Studies

3 Cross-Cutting Risks

## By the end of this section you will be able to

- Categorise threat actors targeting industrial environments.
- Map ICS attacks to the MITRE ATT&CK for ICS matrix.
- Analyse landmark incidents: Stuxnet, Ukraine, TRITON, Colonial.
- Identify supply-chain and insider risk vectors.

# 1

---

## Threat Actors and Frameworks

Section 05 – Threat Landscape

**Nation-state APTs** – Sandworm, Volt Typhoon, Lazarus

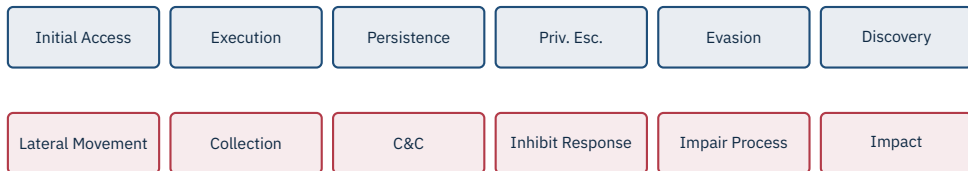
**Cybercrime / Ransomware** – LockBit, BlackCat, Conti

**Hacktivists** – CyberAv3ngers, GhostSec

**Insiders** – disgruntled employees, contractors

**Opportunists** – script kiddies, Shodan hunters

**Competitors** – industrial espionage



## Why this matters

ATT&CK for ICS gives a shared vocabulary for techniques, detections, and incident discussion across teams and vendors.

# 2

---

## Case Studies

Section 05 – Threat Landscape

- **Target:** Fuel Enrichment Plant, Natanz (Iran).
- **Victim hardware:** IR-1 gas centrifuge cascades, driven by Siemens S7-315 / S7-417 PLCs and Vacon / Fararo Paya VFDs.
- **Strategic goal:** delay Iranian uranium enrichment without overt military action.
- **Effect (2009–2010):** an estimated ~1 000 of ~8 700 IR-1s decommissioned at Natanz; enrichment throughput visibly stalled.
- **Attribution (widely reported):** joint US/Israel programme “Olympic Games”.

## Cyber-physical weapon

Code that produces a *physical* effect (mass, energy, motion) by acting on a control system – distinct from data theft or denial of service.

Source: D. Albright, P. Brannan, C. Walrond, *Did Stuxnet Take Out 1,000 Centrifuges at Natanz?*, ISIS, 22 Dec 2010 | R. Langner, *To Kill a Centrifuge*, 2013.





- **4 Windows zero-days** (LNK CVE-2010-2568, print-spooler, two privilege escalations) – unprecedented for a single payload.
- **Stolen code-signing certificates** from Realtek and JMicron used to sign kernel drivers.
- **USB-borne propagation**, then lateral movement on engineering LANs; final stage hooks the Siemens Step7 / WinCC DLLs to inject custom ladder logic.
- **Sabotage logic:** drove Fararo Paya / Vacon VFDs outside spec – alternating ~1 410 Hz and ~2 Hz bursts (normal: ~807–1 210 Hz), stressing rotors over weeks.
- **HMI deception:** 21 seconds of *recorded normal* sensor data played back during attacks – operators saw a healthy plant.

Source: N. Falliere, L. Murchu, E. Chien, *W32.Stuxnet Dossier v1.4*, Symantec, Feb 2011 | R. Langner, *To Kill a Centrifuge*, The Langner Group, Nov 2013.

### ★ Key Takeaway: Why Stuxnet still matters

- **Air gap is not a control.** USB sticks, engineer laptops, and vendor service notebooks cross it routinely. Treat it as a hurdle, not a boundary.
- **Supply chain matters.** Stolen vendor certificates defeated driver-signing checks. Trust placed in suppliers is trust placed in their security.
- **PLCs run unverified code.** S7 PLCs accepted any signed Step7 download; no firmware-level integrity check on logic blocks. Most PLCs still do.
- **The HMI is not ground truth.** A compromised controller can fake telemetry. Independent measurement (process tags, safety I/O, physical inspection) matters.

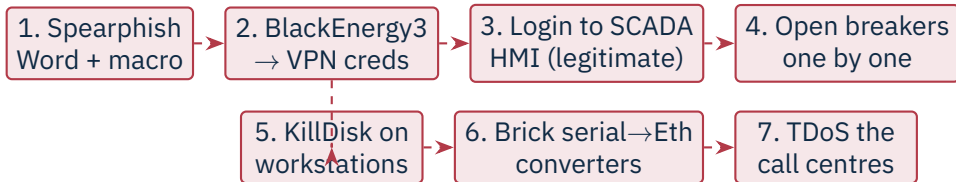
Source: R. Langner, *To Kill a Centrifuge*, 2013 | K. Zetter, *Countdown to Zero Day*, Crown, 2014.

- **When:** 23 December 2015, ~15:35 local time.
- **Who hit:** three regional distribution companies (oblenergos) – Prykarpattiaoblenergo, Chernivtsioblenergo, Kyivoblenergo.
- **Impact:** ~225 000 customers lost power; outages 1–6 hours; restoration required *manual* switching at substations because remote control was destroyed.
- **Aftermath:** weeks of degraded SCADA – operators ran the grid by phone and clipboard.

### First confirmed cyber-induced power outage

Ukraine 2015 demonstrated that a remote actor could move from corporate IT to the SCADA HMI of a distribution operator and switch the lights off – in production, against three utilities, in coordinated fashion.

*Source: R. M. Lee, M. J. Assante, T. Conway, Analysis of the Cyber Attack on the Ukrainian Power Grid, SANS/E-ISAC, 18 Mar 2016.*



## The human-in-the-loop attack

Operators reportedly watched their own mouse cursors move and breakers trip – and were locked out when they tried to intervene. The destruction of serial-to-Ethernet converters and the telephony DoS were not for damage: they delayed *restoration*.

Source: R. M. Lee et al., SANS/E-ISAC, Mar 2016 | ICS-CERT *IR-ALERT-H-16-056-01*, 25 Feb 2016.

- **When:** 17 December 2016, just before midnight.
- **Where:** Pivnichna 330 kV transmission substation, north of Kyiv.
- **Impact:** ~200 MW dropped; ~1 hour outage in parts of Kyiv. Smaller than 2015 in scope – but qualitatively different.
- **Why it stands out:** the first known malware framework *purpose-built* to speak grid protocols, with swappable payload modules.



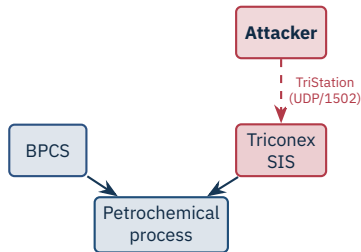
Source: A. Cherepanov, *Win32/Industroyer: A new threat for industrial control systems*, ESET, 12 Jun 2017 | Dragos, *CRASHOVERRIDE: Analysis of the Threat to Electric Grid Operations*, 2017.

- Earlier ICS malware (Stuxnet, Havex) was *target-specific*. Industroyer is a *framework* – swap a payload, hit a different protocol.
- Built-in protocol handlers send legitimate-looking control commands; defenders see normal SCADA traffic.
- The SIPROTEC DoS module attempted to take protective relays *offline* ahead of the breaker operations – a deliberate attack on the safety layer.
- Attributed to **Sandworm** (Russian GRU Unit 74455).

## Reusable grid weaponry

With Industroyer, ICS attack tooling crossed the line from bespoke ordnance to a *platform*. Subsequent variants (Industroyer2, 2022) reused the architecture against a Ukrainian substation – and were stopped before impact.

Source: A. Cherepanov, ESET, 2017 | Dragos, CRASHOVERRIDE, 2017 | ESET & CERT-UA, Industroyer2, 12 Apr 2022.



- **Where:** Saudi petrochemical plant (Tasnee/Sadara reported), Aug 2017.
- **Hit:** Schneider **Triconex** SIS – the last-resort trip-to-safe layer.
- **Goal:** disable SIS so a separate process attack could cause a release, fire, or explosion.
- **Outcome:** payload logic error caused SIS to fail-safe trip – shutting the plant down and exposing the operation.

Source: Dragos, *TRISIS Malware Analysis*, Dec 2017 | Mandiant/FireEye, *Attackers Deploy New ICS Attack Framework "TRITON"*, 14 Dec 2017.

- Attackers reached an engineering workstation with TriStation software, then pivoted onto the SIS network.
- Payload (`trilog.exe` + `library.zip`) spoke the proprietary **TriStation** protocol; exploited a Triconex weakness (CVE-2018-7522) to inject malicious *ladder logic* into the safety controller's RAM.
- Once resident, the implant could rewrite SIS logic – including *neutralising* trip set-points – and restore the original on demand.
- Attribution: **TEMP.Veles** / Xenotime (FSU-linked); US Treasury sanctioned TsNIIKhM in 2020.

### First public attack on a safety layer

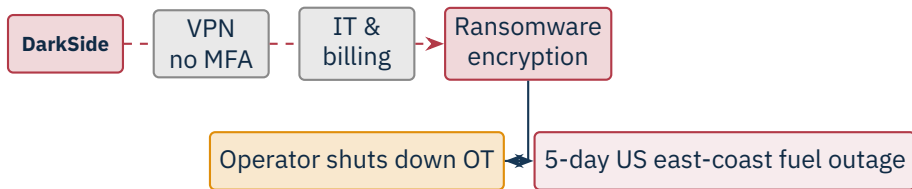
TRITON crossed a long-assumed red line: targeting the SIS deliberately, with intent to disable the layer that prevents loss of life. Subsequent victim discoveries (Schneider, 2019) showed the framework was not a one-off.

Source: Mandiant, *TRITON Attribution: Russian Government Research Institute Connected to the Attacks*, 23 Oct 2018 | U.S. Treasury OFAC press release, 23 Oct 2020.



- **Initial vector:** compromised update of **M.E.Doc**, a Ukrainian tax-accounting product used by virtually every company doing business in Ukraine.
- **Spread:** EternalBlue (MS17-010) + Mimikatz + WMI/PsExec – minutes to ravage a flat Windows domain.
- **Pseudo-ransomware:** encrypted the MFT, demanded \$300 BTC, but “decryption IDs” were random. Intent was destruction.
- **OT-adjacent impact (IT outage took OT down):**
  - **Maersk:** ~\$300 M; rebuilt 4 000 servers, 45 000 PCs in 10 days; container terminals halted.
  - **Merck:** ~\$870 M; vaccine production disrupted.
  - **Mondelēz, FedEx/TNT, Reckitt, Saint-Gobain:** hundreds of millions each.
- Total damage estimated at \$10 B+; attributed by US/UK/EU to **Sandworm** (GRU).

Source: A. Greenberg, *Sandworm*, Doubleday, 2019 | White House attribution statement, 15 Feb 2018 | CISA TA17-181A, 1 Jul 2017.

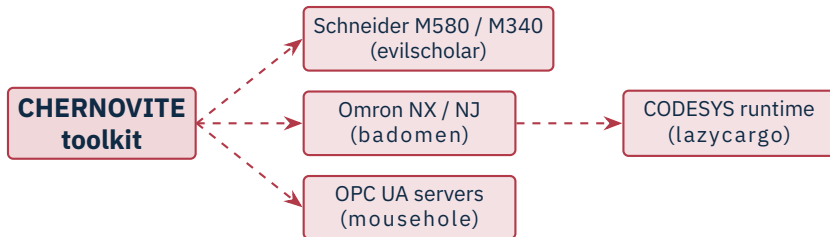


- **7 May 2021:** DarkSide affiliate enters via a reused VPN password; no MFA.
- OT was *not* compromised. Colonial halted the 8 850 km pipeline because billing/dispatch IT was down.
- \$4.4 M ransom paid; ~half later recovered by the FBI; fuel shortages in 17 states.

## ★ Key Takeaway: IT/OT dependencies cut both ways

You can shut down OT without touching it – if the IT it depends on goes down.

Source: FBI, *Statement on Colonial Pipeline*, 10 May 2021 | GAO-22-104746, 2022.



## Caught before deployment

PIPEDREAM is the first modular ICS attack framework discovered *before any victim impact*. Pre-built modules for Schneider, Omron and OPC UA; capable of scanning, parameter changes, logic upload, and denial of control. Interdicted via early reporting by a partner.

Source: CISA AA22-103A, "APT Cyber Tools Targeting ICS/SCADA Devices", 13 Apr 2022 | Dragos, *PIPEDREAM/CHERNOVITE* report, Apr 2022 | Mandiant, *INCONTROLLER*, Apr 2022.

## The basics still get exploited

**Default credentials** (1111) and **direct Internet exposure** of PLCs are still common – and still get exploited by low-skill actors at scale.



- **25 Nov 2023:** Municipal Water Authority of Aliquippa, PA – booster station PLC defaced, manual fallback used; no contamination.
- Same actor hit *multiple* US water utilities and other CNI sites using identical access pattern: scan, log in with default password, deface, optionally wipe.
- No process damage observed – but with engineering access to a Vision PLC, the attacker *could* have manipulated setpoints.

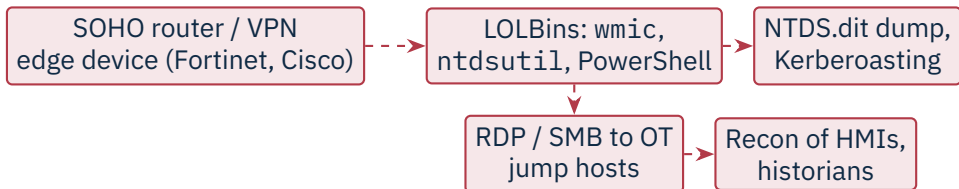
Source: CISA AA23-335A, “IRGC-Affiliated Cyber Actors Exploiting PLCs in Multiple Sectors, Including U.S. Water and Wastewater Systems Facilities”, 1 Dec 2023.

- Suspected PRC-linked APT, active since at least 2021.
- Targets: US critical infrastructure – communications, energy, water, transportation – with emphasis on assets serving **Guam** and the US west coast.
- Apparent objective: *pre-position* for disruptive or destructive action against OT during a future geopolitical crisis (e.g. Taiwan contingency).
- Dwell time before discovery in several victims: **five years or more**.

### Caution

From espionage to pre-positioning Volt Typhoon's target list (water, power, ports) and its persistence in OT-adjacent environments are consistent with preparation to *disrupt*, not to spy – a notable shift in intent.

Source: CISA AA24-038A, 7 Feb 2024 | Microsoft Threat Intelligence, *Volt Typhoon targets US critical infrastructure with living-off-the-land techniques*, 24 May 2023.



- **Initial access:** CVEs in Internet-facing Fortinet, Ivanti, Cisco appliances; or stolen creds.
- **Living off the land:** almost no custom malware – built-in Windows tools, signed binaries, multi-hop proxying through compromised SOHO routers (the “KV-botnet”).
- **Behaviour, not signatures:** the hardest threat to detect is the one that looks like a normal admin task.

*Source: CISA AA24-038A, 7 Feb 2024 | Lumen Black Lotus Labs, KV-botnet, Dec 2023 | Microsoft, May 2023.*

# 3

---

## Cross-Cutting Risks

Section 05 – Threat Landscape



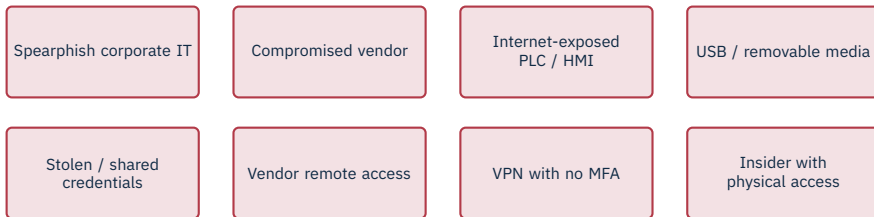
SolarWinds, 3CX, MOVEit – and OT-relevant cases such as Codesys runtime CVEs (*CoDe16*).





Maroochy Shire (2000): ex-contractor with a stolen radio modem released sewage 46 times.

Source: J. Slay & M. Miller, "Lessons learned from the Maroochy Water breach", *Critical Infrastructure Protection*, IFIP, 2008.



Source: Dragos Year in Review 2024 – initial access vectors observed across 23 OT-targeting groups.

### ★ Key Takeaway: What to remember from this section

- Threat actors range from script kiddies to nation-state APTs, each with different capabilities and intent.
- MITRE ATT&CK for ICS provides a shared vocabulary for techniques and detections.
- Stuxnet → Ukraine 2015 → Industroyer → TRITON → PIPEDREAM shows escalating capability and willingness to harm.
- NotPetya and Colonial Pipeline show that IT/OT coupling can take OT down without any OT compromise.
- Volt Typhoon shows that pre-positioning inside CNI – not espionage – is now an explicit objective.
- Supply chain and insider risk demand controls beyond the network perimeter.

- Falliere, N., Murchu, L., Chien, E. *W32.Stuxnet Dossier*, v1.4. Symantec, Feb 2011.
- Langner, R. *To Kill a Centrifuge*, The Langner Group, Nov 2013.
- Albright, D., Brannan, P., Walrond, C. *Did Stuxnet take out 1,000 centrifuges at Natanz?* ISIS, 22 Dec 2010.
- Zetter, K. *Countdown to Zero Day: Stuxnet and the Launch of the World's First Digital Weapon*. Crown, 2014.
- Lee, R.M., Assante, M.J., Conway, T. *Analysis of the Cyber Attack on the Ukrainian Power Grid*, SANS/E-ISAC, 18 Mar 2016.
- ICS-CERT. *IR-ALERT-H-16-056-01: Cyber-Attack Against Ukrainian Critical Infrastructure*, 25 Feb 2016.
- Cherepanov, A. *Win32/Industroyer: A new threat for industrial control systems*, ESET, 12 Jun 2017.
- Dragos. *CRASHOVERRIDE: Analysis of the Threat to Electric Grid Operations*, 2017.
- ESET and CERT-UA. *Industroyer2: Industroyer reloaded*, 12 Apr 2022.
- Dragos. *TRISIS Malware Analysis of Safety System Targeted Malware*, Dec 2017.
- Mandiant/FireEye. *Attackers Deploy New ICS Attack Framework "TRITON"*, 14 Dec 2017.
- Mandiant. *TRITON Attribution: Russian Government Research Institute Connected to the Attacks*, 23 Oct 2018.
- U.S. Treasury OFAC. Press release on TsNIIKhM sanctions (TRITON), 23 Oct 2020.
- CISA TA17-181A. "Petya Ransomware", 1 Jul 2017.
- White House. Statement attributing NotPetya to the Russian Government, 15 Feb 2018.

- Greenberg, A. *Sandworm: A New Era of Cyberwar and the Hunt for the Kremlin's Most Dangerous Hackers*. Doubleday, 2019.
- FBI. *Statement on the Colonial Pipeline attack*, 10 May 2021.
- GAO-22-104746. *Critical Infrastructure Protection: Federal Authorities – Colonial Pipeline Response*, 2022.
- TSA. *Security Directive Pipeline-2021-01*, May 2021.
- CISA AA22-103A. “APT Cyber Tools Targeting ICS/SCADA Devices” (PIPEDREAM/INCONTROLLER), 13 Apr 2022.
- Mandiant. *INCONTROLLER: New State-Sponsored Cyber Attack Tools*, Apr 2022.
- Dragos. *PIPEDREAM/CHERNOVITE*, Apr 2022.
- CISA AA23-335A. “IRGC-Affiliated Cyber Actors Exploiting PLCs in Multiple Sectors”, 1 Dec 2023.
- CISA AA24-038A. “PRC State-Sponsored Actors Compromise and Maintain Persistent Access to U.S. Critical Infrastructure” (Volt Typhoon), 7 Feb 2024.
- Microsoft Threat Intelligence. *Volt Typhoon targets US critical infrastructure with living-off-the-land techniques*, 24 May 2023.
- Lumen Black Lotus Labs. *KV-botnet: Don't call it a comeback*, Dec 2023.
- Slay, J., Miller, M. “Lessons learned from the Maroochy Water breach.” In *Critical Infrastructure Protection*, IFIP, 2008.
- MITRE. *ATT&CK for ICS*, knowledge base, <https://attack.mitre.org/matrices/ics/>.
- Dragos. *Year in Review*, annual reports.

# End of Section 05



Threat Landscape

Questions and discussion